

VPR (Vulnerability Priority Rating) — Study Guide

VPR is Tenable's (Nessus's) proprietary risk-prioritization score — created specifically to address CVSS's biggest limitation, covered at the end of your CVSS guide: **CVSS tells you how bad a vulnerability theoretically is, VPR tells you how urgently you should actually fix it right now, in the real world.**

1. Why VPR Exists — The Problem It Solves

Most organizations have far more "High" and "Critical" CVSS findings than they could ever patch immediately. If you treat every 9.0+ CVSS score as equally urgent, you end up either overwhelmed or patching things in the wrong order — a Critical CVSS vulnerability with no real-world exploit code and low attacker interest might genuinely be less urgent than a Medium-CVSS vulnerability that's being actively exploited by ransomware groups right now.

CVSS → "How bad is this vulnerability, theoretically, in a vacuum?"
VPR → "How urgently do I need to actually fix this, given what's happening in the real world today?"

2. What Feeds Into a VPR Score

Unlike CVSS's fixed, unchanging Base Score, VPR is **dynamic** — it changes over time as real-world conditions change, and factors in:

Factor	What It Considers
Threat Intelligence	Is this CVE being actively discussed/weaponized in threat actor communities, dark web forums, exploit kits?
Exploit Code Maturity	Does public, working exploit code exist (Metasploit module, PoC on GitHub)? Or is it purely theoretical?
Threat Recency	How recently has this vulnerability been actively exploited in the wild?
Product Coverage/Popularity	How widely deployed is the affected software? (wider deployment = more attacker interest)
CVSS Base Metrics	Still factored in as one input among several, not ignored entirely

This means a VPR score is essentially: *CVSS severity + live threat intelligence + exploit availability, continuously recalculated.*

3. VPR Scale

Same 0.0–10.0 range as CVSS, but the *meaning* is different:

Score Range	VPR Category
0.1 – 3.9	Low
4.0 – 6.9	Medium
7.0 – 8.9	High
9.0 – 10.0	Critical

The key insight: a vulnerability can have a **CVSS of 9.8** but a **VPR of 4.2** if there's genuinely no known exploit and no active threat actor interest — and conversely, a **CVSS of 7.0** vulnerability with active, widespread exploitation happening right now might carry a **VPR of 9.5**. Seeing this divergence in a real Nessus report is the moment VPR's value clicks conceptually.

4. Where You'll See VPR

VPR is specifically a **Tenable/Nessus feature** (via their Predictive Prioritization / Lumin platform) — you won't find it on NVD or in OpenVAS, since it's proprietary threat-intelligence-driven scoring, not an open industry standard like CVSS.

```
Nessus scan results → each finding shows BOTH:  
  CVSS Base Score   → static severity  
  VPR Score         → dynamic, real-world prioritization
```

5. Practical Example — Why This Changes Your Patching Priority

```
Finding A: CVE-XXXX-1111  
  CVSS: 9.8 (Critical)  
  VPR:  4.1 (Low-Medium)  
  → No known public exploit, low real-world attacker interest,  
  affects a niche/rarely-deployed product
```

Finding B: CVE-XXXX-2222

CVSS: 7.5 (High)

VPR: 9.6 (Critical)

→ Active exploitation observed in the wild, Metasploit module publicly available, widely deployed software (e.g., a popular CMS plugin)

A patch team working strictly off CVSS would prioritize Finding A first — VPR correctly flags Finding B as the actual urgent fix. This exact scenario is the entire reason VPR (and similar risk-based vulnerability management approaches) exist.

6. VPR in the Broader "Risk-Based Vulnerability Management" Trend

VPR is Tenable's specific implementation of a broader industry shift called **Risk-Based Vulnerability Management (RBVM)** — the recognition that raw CVSS scores alone don't scale to real prioritization decisions. Other vendors have their own equivalents worth knowing exist, even without deep-diving each:

Vendor/Framework	Equivalent Concept
Tenable	VPR
CISA	KEV (Known Exploited Vulnerabilities) catalog — a free, public list of CVEs with confirmed active exploitation
FIRST.org	EPSS (Exploit Prediction Scoring System) — an open, free, statistical model predicting exploitation likelihood

EPSS is genuinely worth knowing in more depth since, unlike VPR, it's completely free and open — a great complement to CVSS for anyone building tools without a Tenable license (directly relevant to a possible SmartScan enhancement):

```
curl "https://api.first.org/data/v1/epss?cve=CVE-2017-0144"
```

This returns a probability score (0-1) representing the likelihood of exploitation in the next 30 days, based on real observed exploitation data — free, API-accessible, and conceptually doing much of what VPR does commercially.

7. CISA KEV — The Free Government Equivalent Worth Knowing

The **CISA Known Exploited Vulnerabilities (KEV) catalog** is a public, continuously updated list of CVEs with *confirmed* real-world exploitation — U.S. federal agencies are required to patch anything on this list within a mandated timeframe, making it a genuinely authoritative, free signal for prioritization.

```
https://www.cisa.gov/known-exploited-vulnerabilities-catalog
```

```
curl "https://www.cisa.gov/sites/default/files/feeds/known_exploited_vulnerabilities.json"
```

Cross-referencing your own scan findings against the KEV catalog is a completely free way to add real-world prioritization context without needing Tenable's paid VPR feature — genuinely worth building into a future SmartScan version.

8. Practical Prioritization Framework (Combining Everything)

```
1. CVSS Base Score           → baseline technical severity
2. CISA KEV catalog check    → is this being actively exploited RIGHT NOW? (free, authoritative)
3. EPSS score                 → statistical exploitation probability (free, API-accessible)
4. VPR (if you have Tenable) → Tenable's proprietary version of the same combined signal
5. Your own environmental context → is this internet-facing? Does a compensating control exist?

↓
Final prioritized patch order
```

This layered approach — CVSS + KEV + EPSS — is essentially free-tier VPR, and is exactly the kind of prioritization logic that separates a report that just lists CVSS scores from one that demonstrates real risk-based thinking.

9. Kill Chain / ATT&CK Mapping

VPR (and RBVM generally) doesn't map to a specific ATT&CK technique — it's a **defensive prioritization framework** that sits alongside the vulnerability scanning tools (Nessus/OpenVAS/Nuclei) used during Reconnaissance and

informs which findings actually warrant remediation urgency from a defender's perspective.

Quick Reference Cheat Sheet

```
CVSS → static, theoretical severity (0.0-10.0)
VPR → dynamic, real-world prioritized urgency (0.0-10.0), Tenable-specific
EPSS → free, open exploitation-probability score (0-1), from FIRST.org
CISA KEV → free, authoritative "actively exploited right now" list
```

```
# EPSS lookup
```

```
curl "https://api.first.org/data/v1/epss?cve=CVE-XXXX-XXXXX"
```

```
# CISA KEV catalog
```

```
curl "https://www.cisa.gov/sites/default/files/feeds/known_exploited_vulnerabilities.json"
```